

Computer Security Capstone

Chapter 24: Wireless Network Security

Chi-Yu Li (2025 Spring)

Computer Science Department

National Yang Ming Chiao Tung University

Outline

- Wireless Security
- Mobile Device Security
- IEEE 802.11 Wireless LAN Overview
- IEEE 802.11i Wireless LAN Security

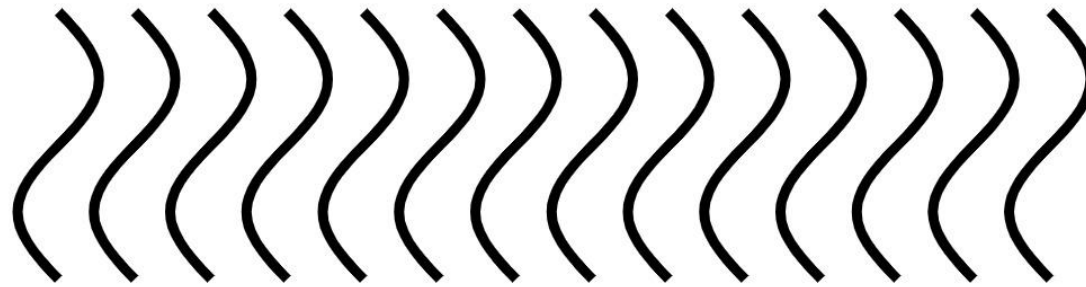
Wireless Security

- Key factors: contributing to higher security risks (v.s. wired networks)
 - Channel
 - Broadcast communications: more susceptible to eavesdropping and jamming
 - Vulnerabilities in communication protocols
 - Mobility
 - More portable and mobile
 - Resources
 - Smartphones/tablets: sophisticated OS but limited memory and processing resources
 - Accessibility
 - Sensors/robots: may be left unattended in remote and/or hostile locations

Wireless Networking Components

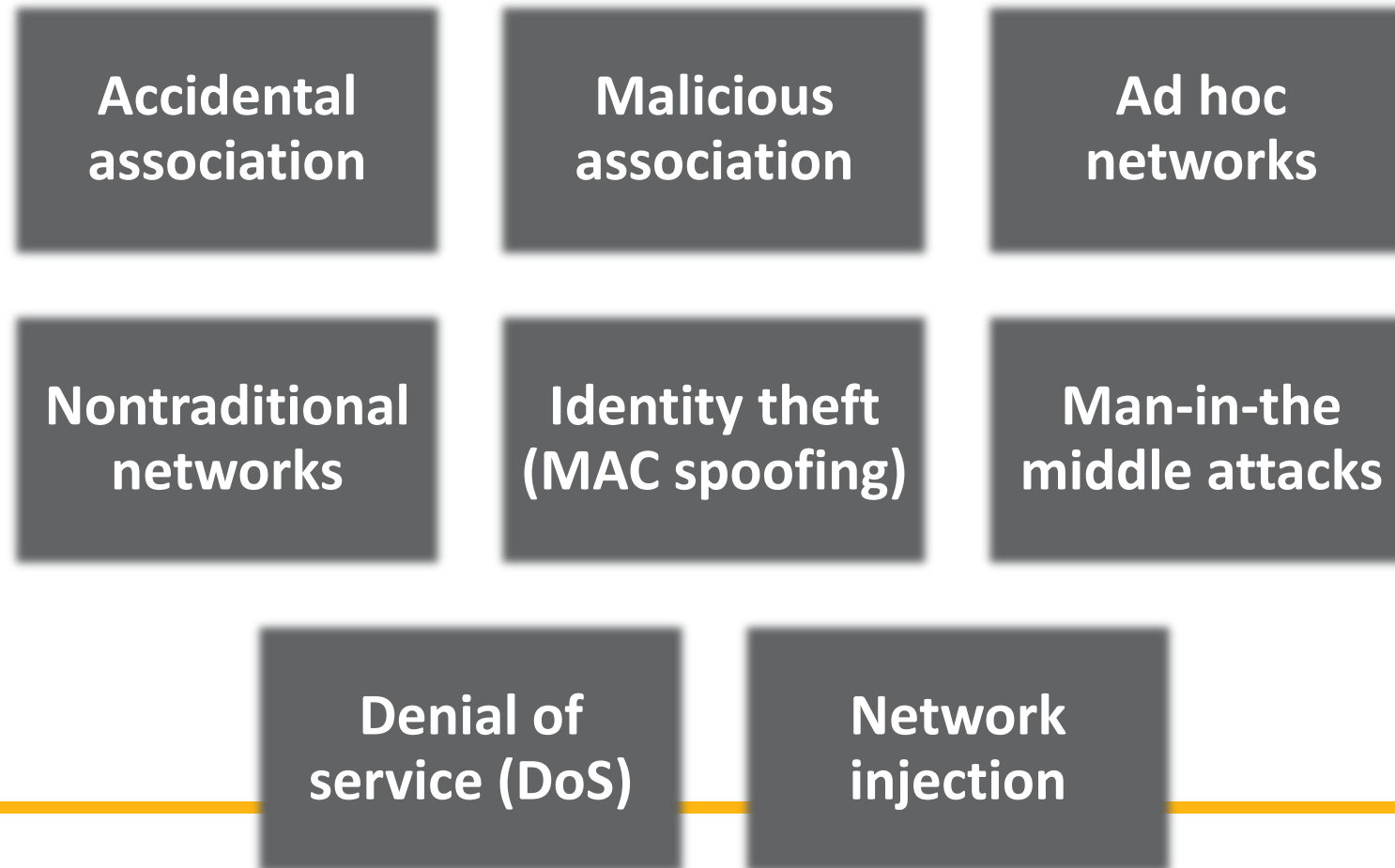


Endpoint



Access point

Wireless Network Threats



Wireless Security Measures

- Securing wireless transmissions

- Principal threats: eavesdropping, altering/inserting messages, and disruption
- Countermeasures for eavesdropping
 - Signal-hiding techniques
 - Encryption
- For altering and inserting
 - Encryption and authentication protocols
- For disruption
 - Detection

Wireless Security Measures (Cont.)

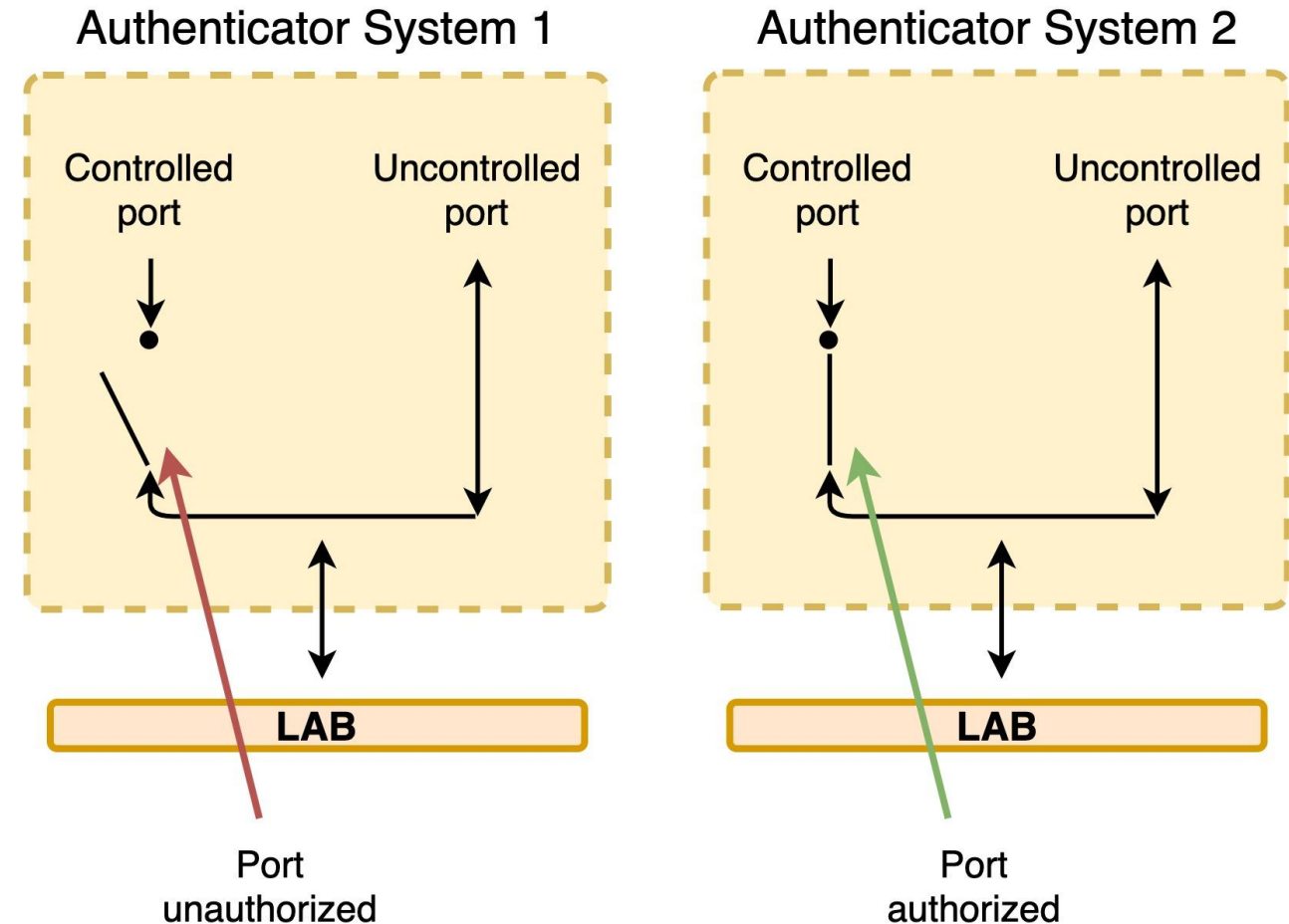
● Securing wireless networks

□ Wireless APs

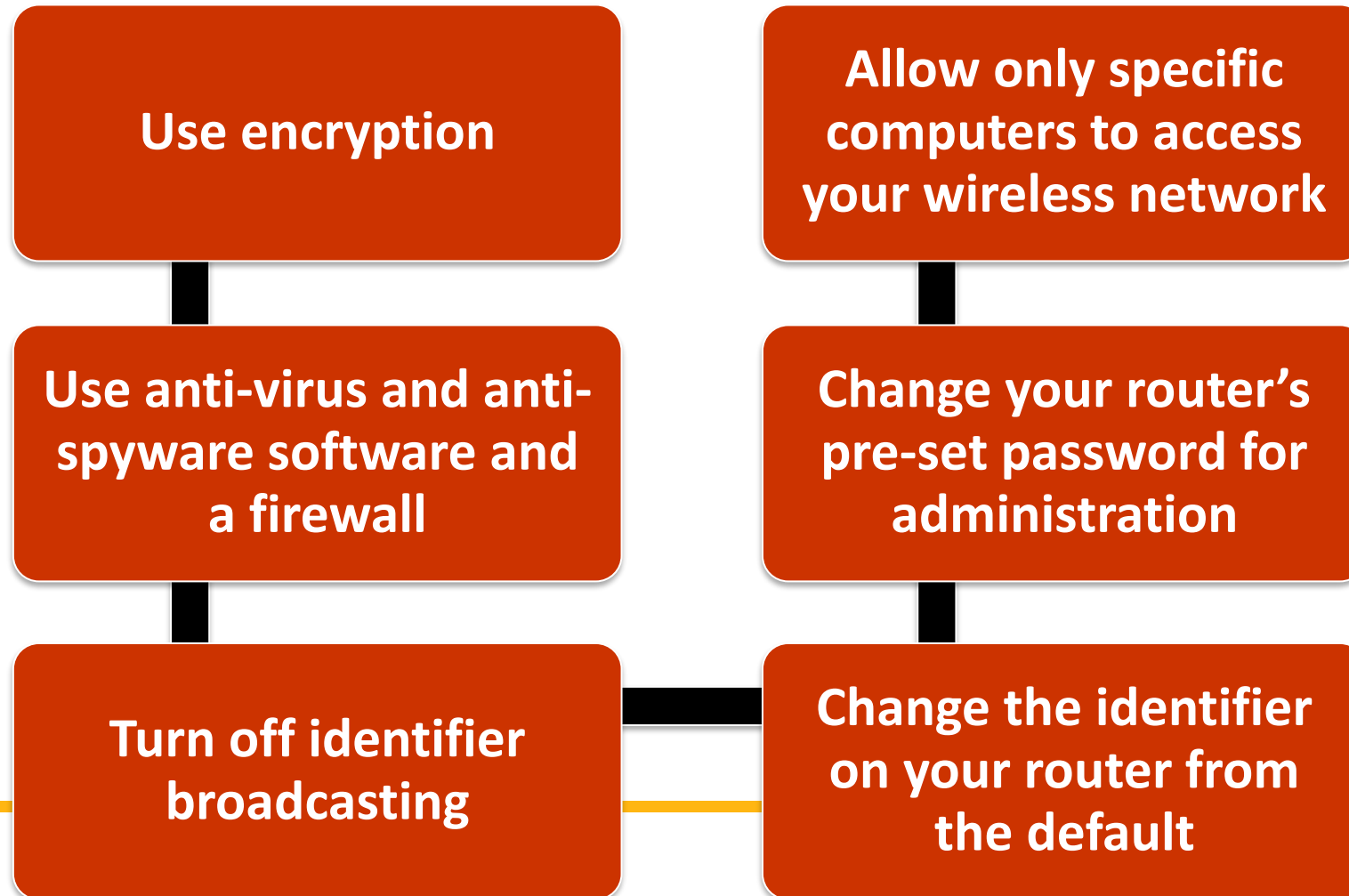
- Unauthorized access to the network

□ Principal approach: IEEE 802.1X (port-based network access control)

- Provide an authentication mechanism
- Prevent rogue APs and other unauthorized devices



Wireless Network Security Techniques



Mobile Device Security

- An organization's networks must accommodate
 - Growing use of new devices
 - Significant growth in employee's use of mobile devices
 - Cloud-based apps
 - Apps no longer run solely on physical servers
 - De-perimeterization
 - A multitude of network perimeters around devices, apps, user, and data
 - External business requirements
 - Provide guests, third-party contractors, and business partners network access

Security Threats

Lack of physical
security controls

Use of untrusted
networks

Use of untrusted
mobile devices

Use of applications
created by unknown
parties

Interaction with
other systems

Use of untrusted
content

Use of location
services

Mobile Device Security Strategy

● Device security

- ❑ Supply mobile devices for employee use and pre-configure those devices
- ❑ or bring-your-own-device (BYOD) policy
 - Configuration guidelines for OS and apps (e.g., rooted is not allowed)

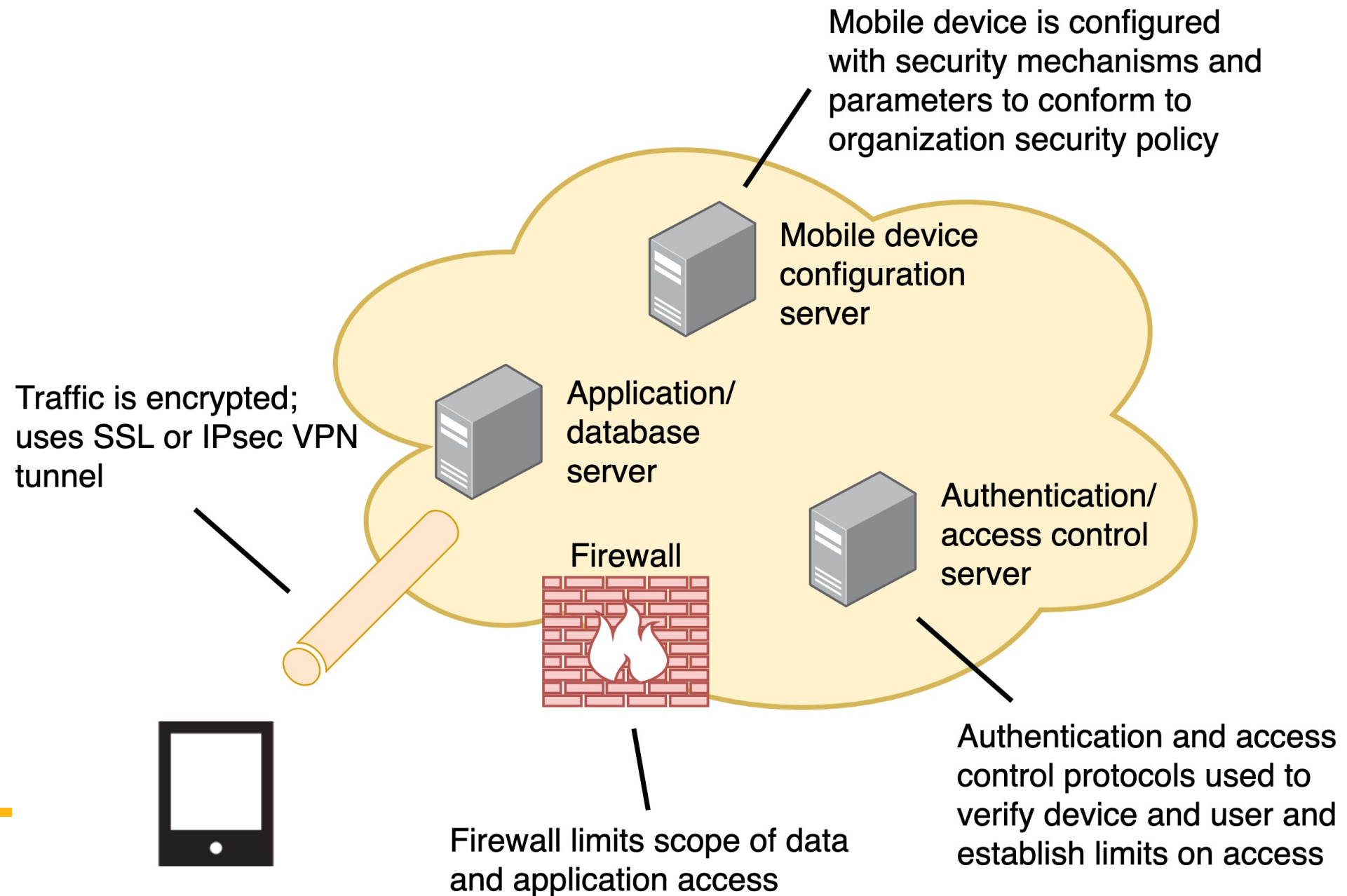
● Traffic security

- ❑ based on encryption and authentication
- ❑ via a VPN

● Barrier security

- ❑ Firewall policies specific to mobile device traffic

Mobile Device Security Elements



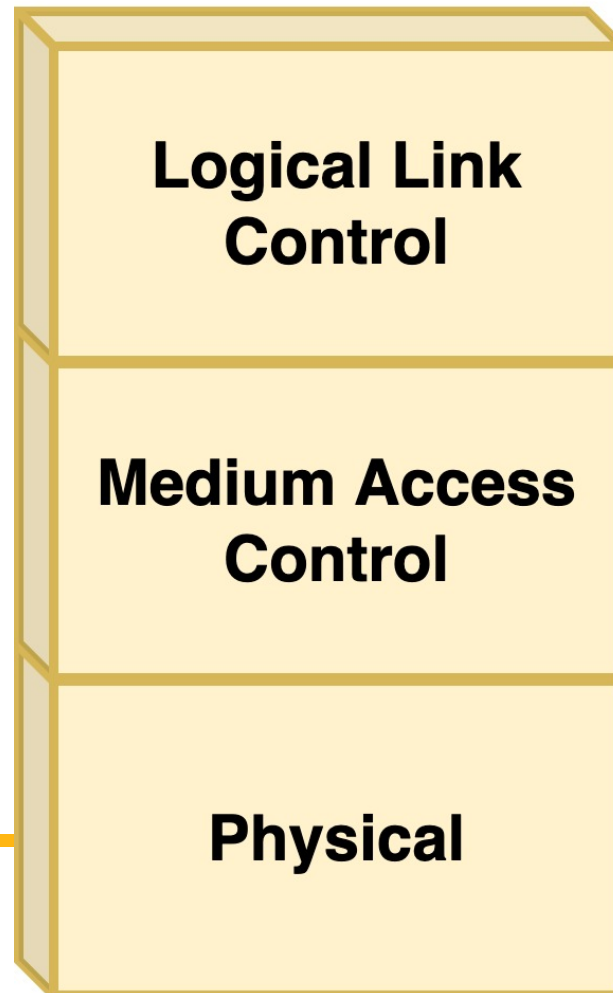
IEEE 802.11 Terminology

Access point (AP)	Any entity that has station functionality and provides access to the distribution system via the wireless medium for associated station.
Basic service set (BSS)	A set of stations controlled by a single coordination function.
Coordination function	The logical function that determines when a station operating within a BSS is permitted to transmit and may be able to receive PDUs.
Distribution system (DS)	A system used to interconnect a set of BSSs and integrated LANs to create an ESS.
Extended service set (ESS)	A set of one or more interconnected BSSs and integrated LANs that appear as a single ESS to the LLC layer at any station associated with one of these BSSs.
MAC protocol data unit (MPDU)	The unit of data exchanged between two peer MAC entities using the services of the physical layer.
MAC service data unit (MSDU)	Information that is delivered as a unit between MAC users.
Station	Any device that contains an IEEE 802.11 conformant MAC and physical layer.

Wireless Fidelity (Wi-Fi) Alliance

- 802.11b
 - ❑ First 802.11 standard to gain broad industry acceptance
- Wireless Ethernet Compatibility Alliance (WECA)
 - ❑ Industry consortium formed in 1999: interoperation between vendors
- Term used for certified 802.11b products: Wi-Fi
- Wi-Fi Protected Access (WPA)
 - ❑ Certification procedures for IEEE802.11 security standards
 - ❑ Most recent version: WPA2/WPA3

IEEE 802.11 Protocol Stack



General IEEE 802 functions



Flow control
Error control

Assemble data
info frame
Addressing
Error detection
Medium access

Encoding/decoding
of signals
Bit transmission/
reception
Transmission medium

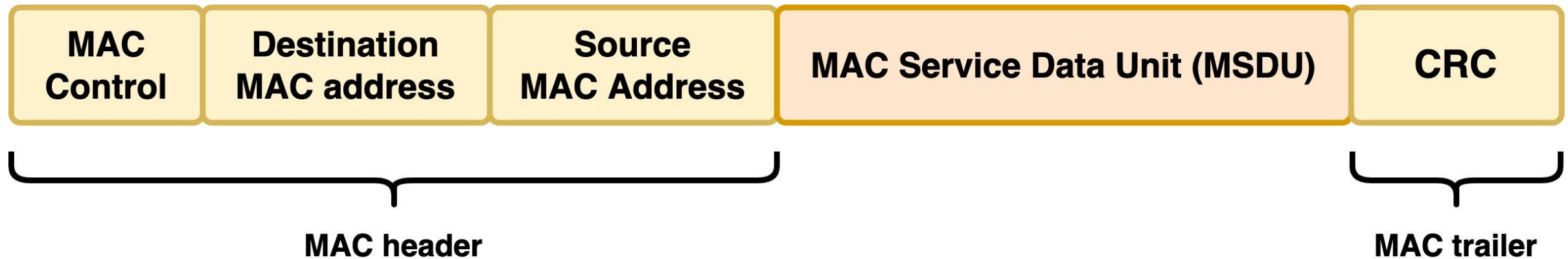
Specific IEEE 802.11 functions



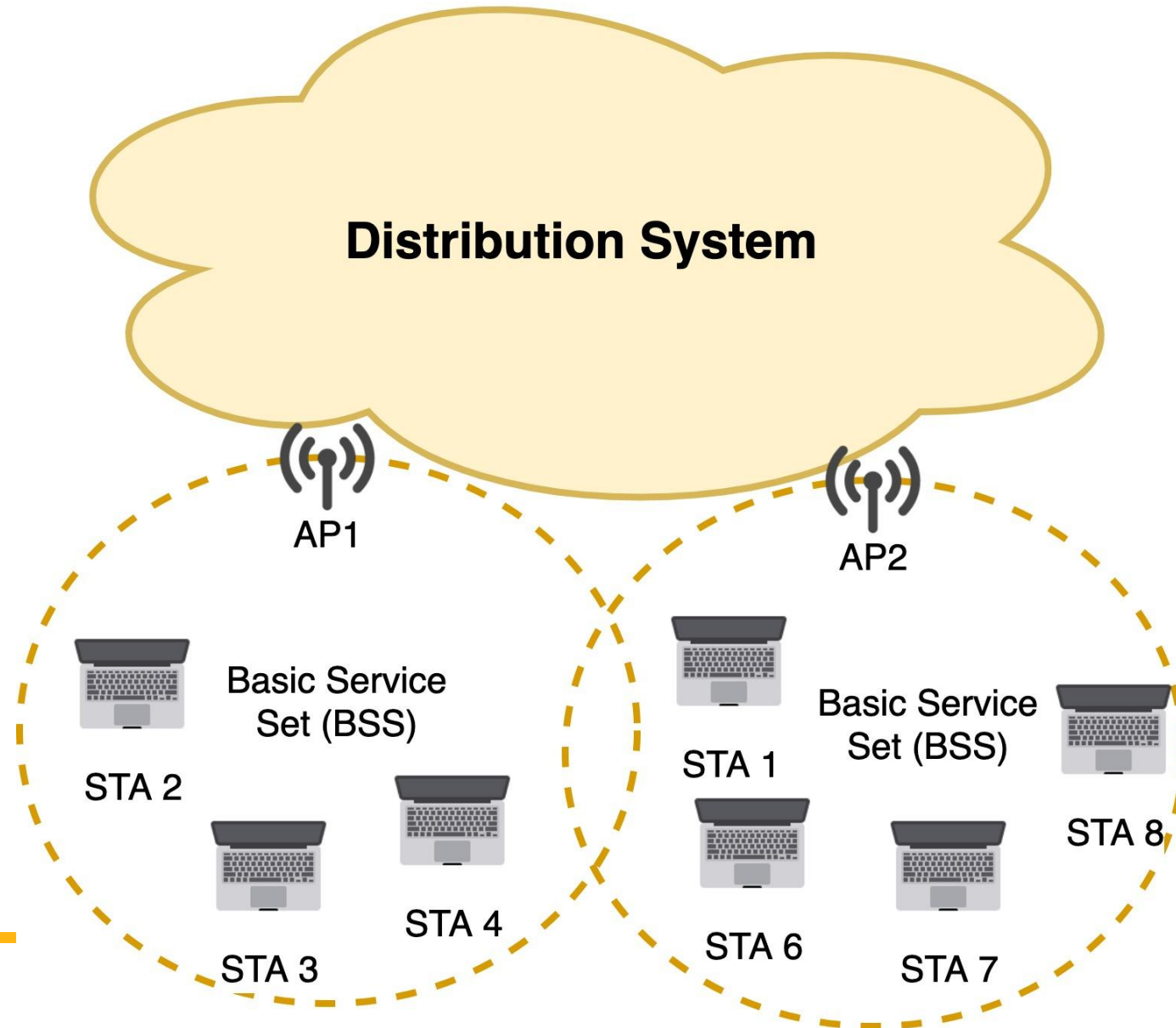
Reliable data delivery
Wireless access control
protocols

Frequency band
definition
Wireless signal
encoding

General IEEE 802 MPDU Format



IEEE 802.11 Extended Service Set

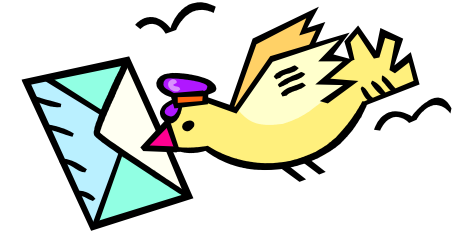


IEEE 802.11 Services

Service	Provider	Used to support
Association	Distribution system	MSDU delivery
Authentication	Station	LAN access and security
Deauthentication	Station	LAN access and security
Disassociation	Distribution system	MSDU delivery
Distribution	Distribution system	MSDU delivery
Integration	Distribution system	MSDU delivery
MSDU delivery	Station	MSDU delivery
Privacy	Station	LAN access and security
Reassociation	Distribution system	MSDU delivery

Distribution of Messages within a DS

- Two services involved



Distribution

- Exchange MPDUs between two BSS

Integration

- Data transfer between a Wi-Fi station and an LAN station on an integrated IEEE 802x LAN

Association-Related Services

- Transition types, based on mobility:
 - No transition
 - Move only within a single BSS
 - BSS transition
 - Move between two BSS
 - ESS transition
 - Move from a BSS in one ESS to a BSS within another ESS

Distribution Service

- Association

- ❑ Establishes an initial association between a station and an AP

- Reassociation

- ❑ Enables an established association to be transferred from one AP to another

- Disassociation

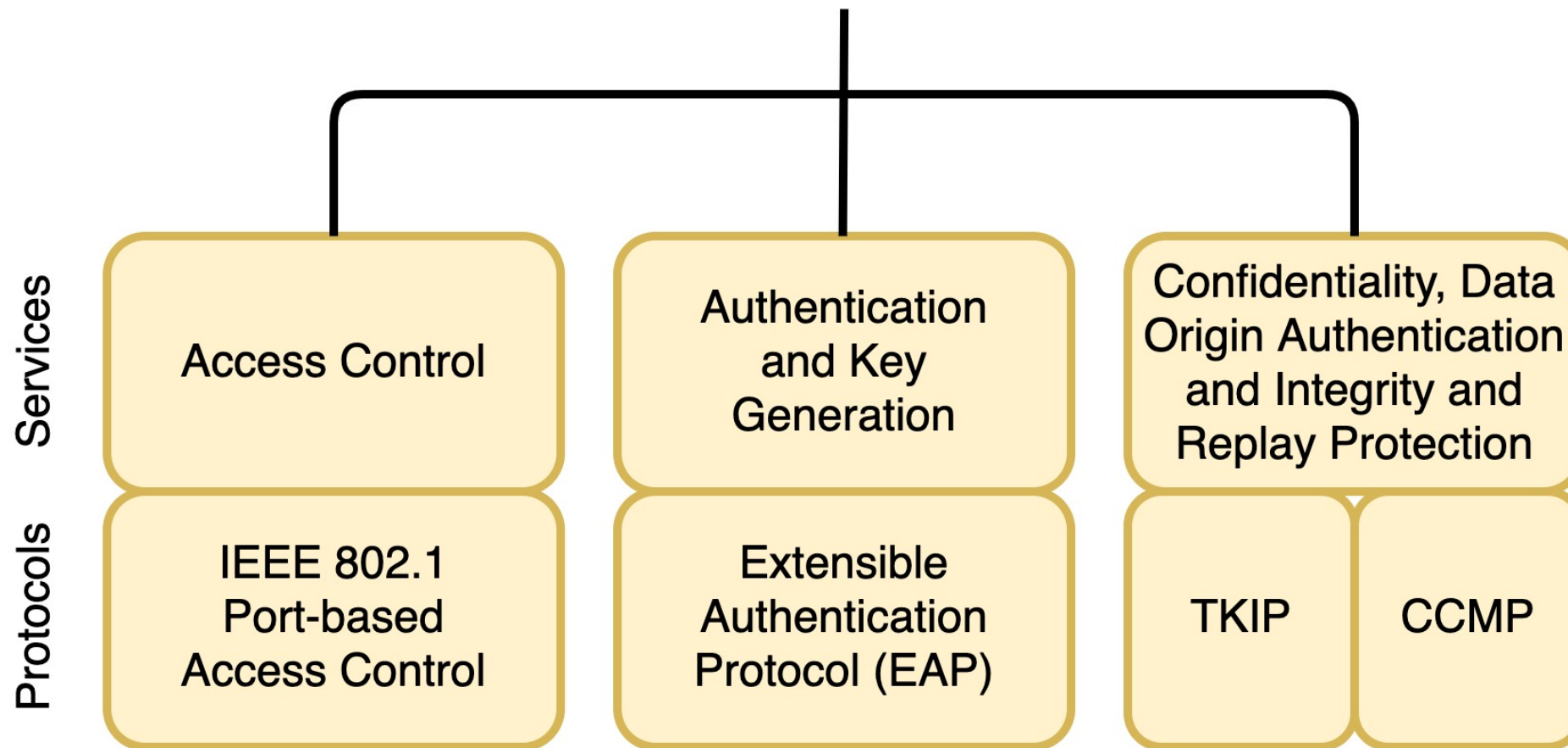
- ❑ A notification from either a station or an AP that an existing association is terminated

Wireless LAN Security: IEEE 802.11i

- Wired Equivalent Privacy (WEP) algorithm
 - 802.11 privacy
- Wi-Fi Protected Access (WPA)
 - Set of security mechanisms: eliminates most 802.11 security issues
 - Based on the current state of the 802.11i standard
- Robust Security Network (RSN)
 - Final form of the 802.11i standard
- Wi-Fi Alliance certifies vendors in compliance with the full 802.11i (WPA2)

Elements of IEEE 802.11i

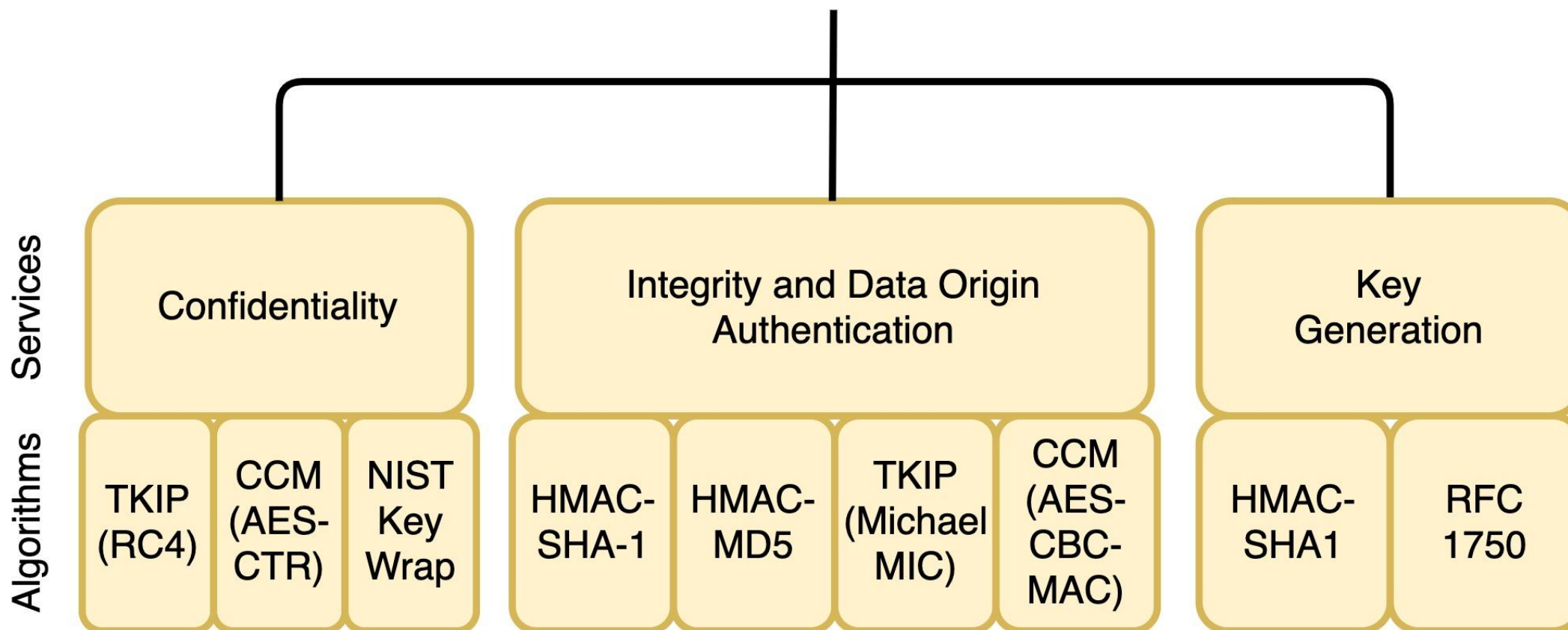
Robust Security Network (RSN)



Services and Protocols

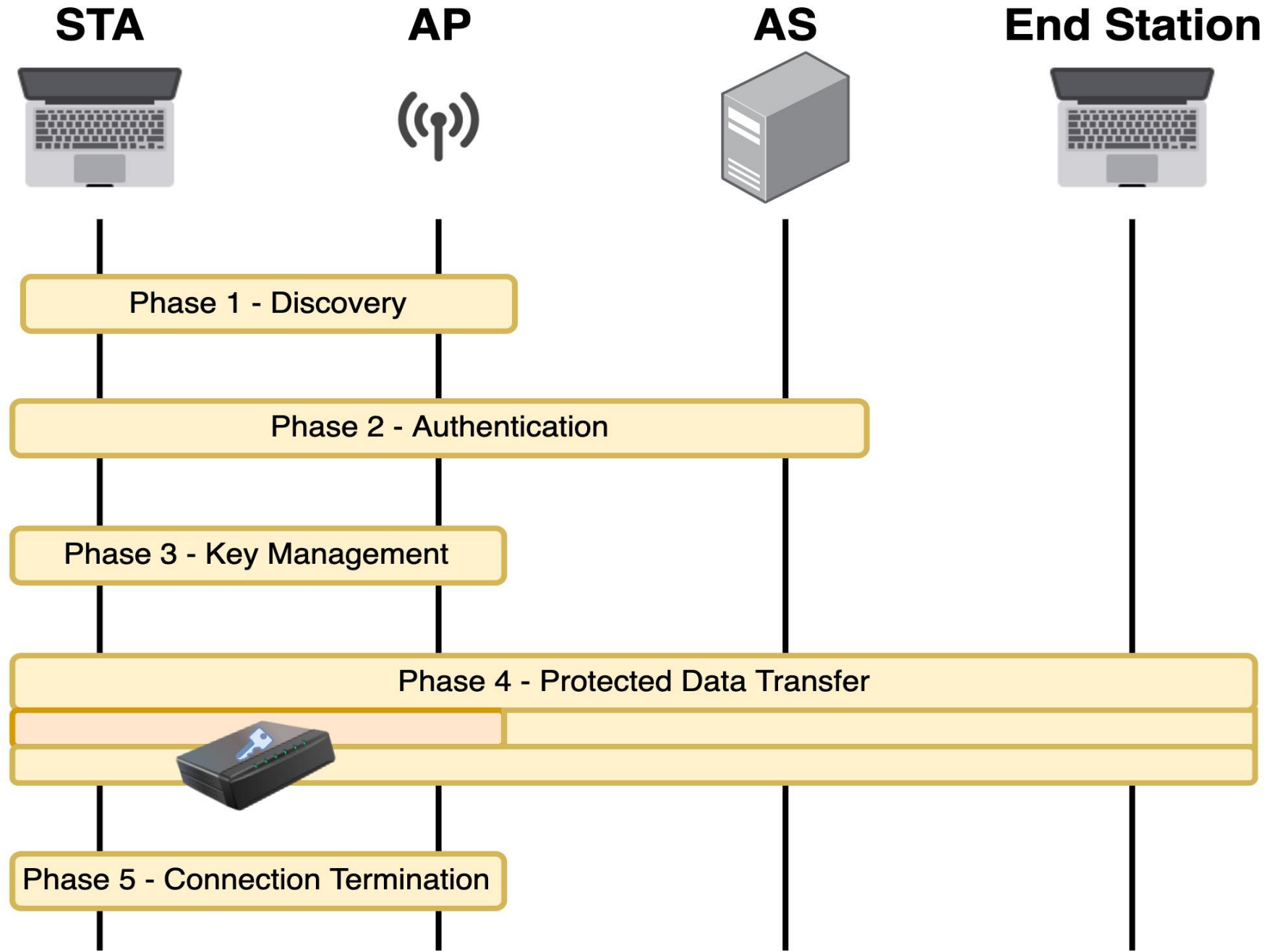
Elements of IEEE 802.11i (Cont.)

Robust Security Network (RSN)



Cryptographic algorithms

Five Phases of Operation for an RSN



Discovery Phase

Security capabilities

- Confidentiality and MPDU integrity protocols (only unicast)
- Authentication method
- Cryptography key management approach

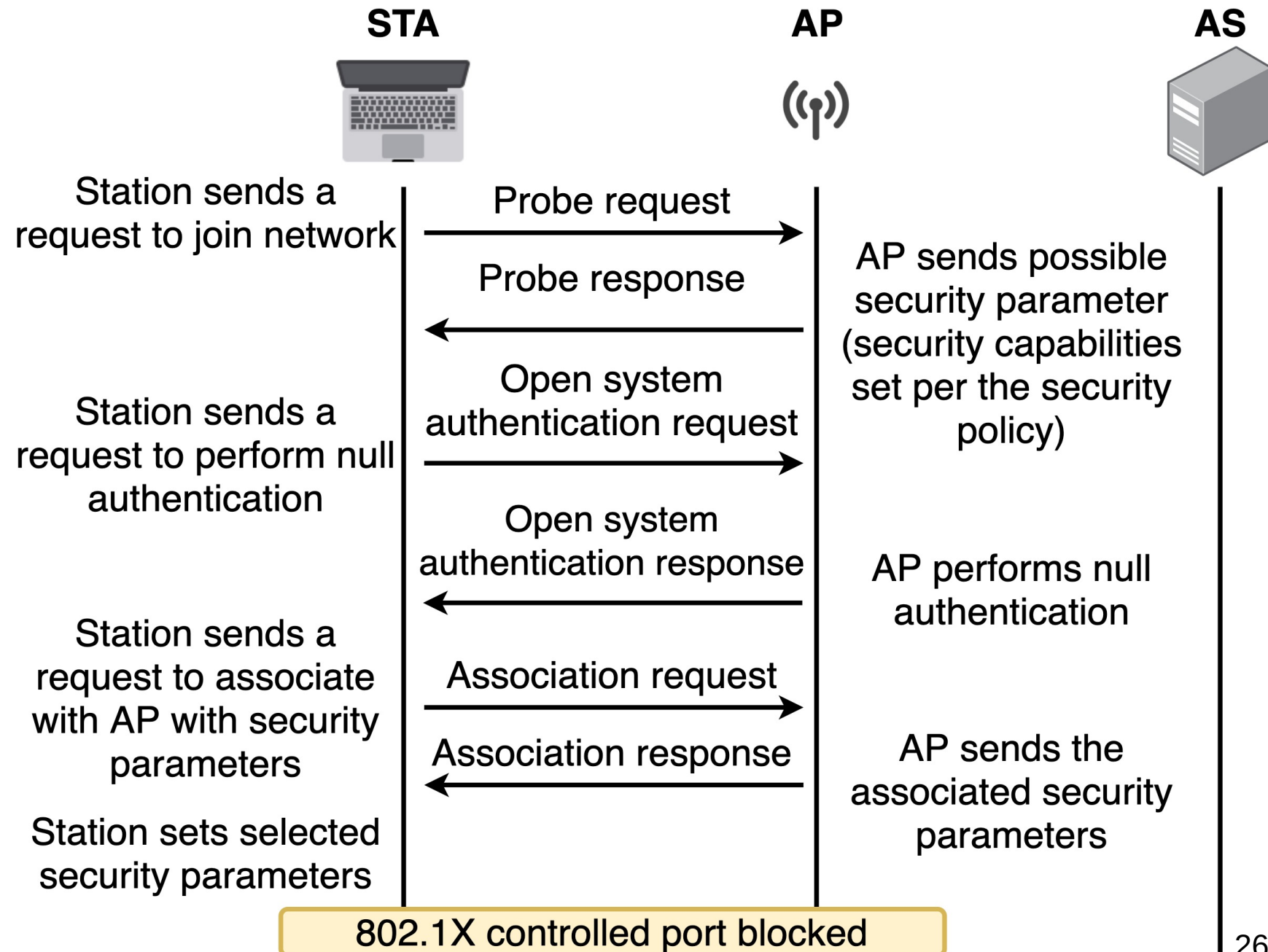
Cipher suite

(Confidentiality/integrity)

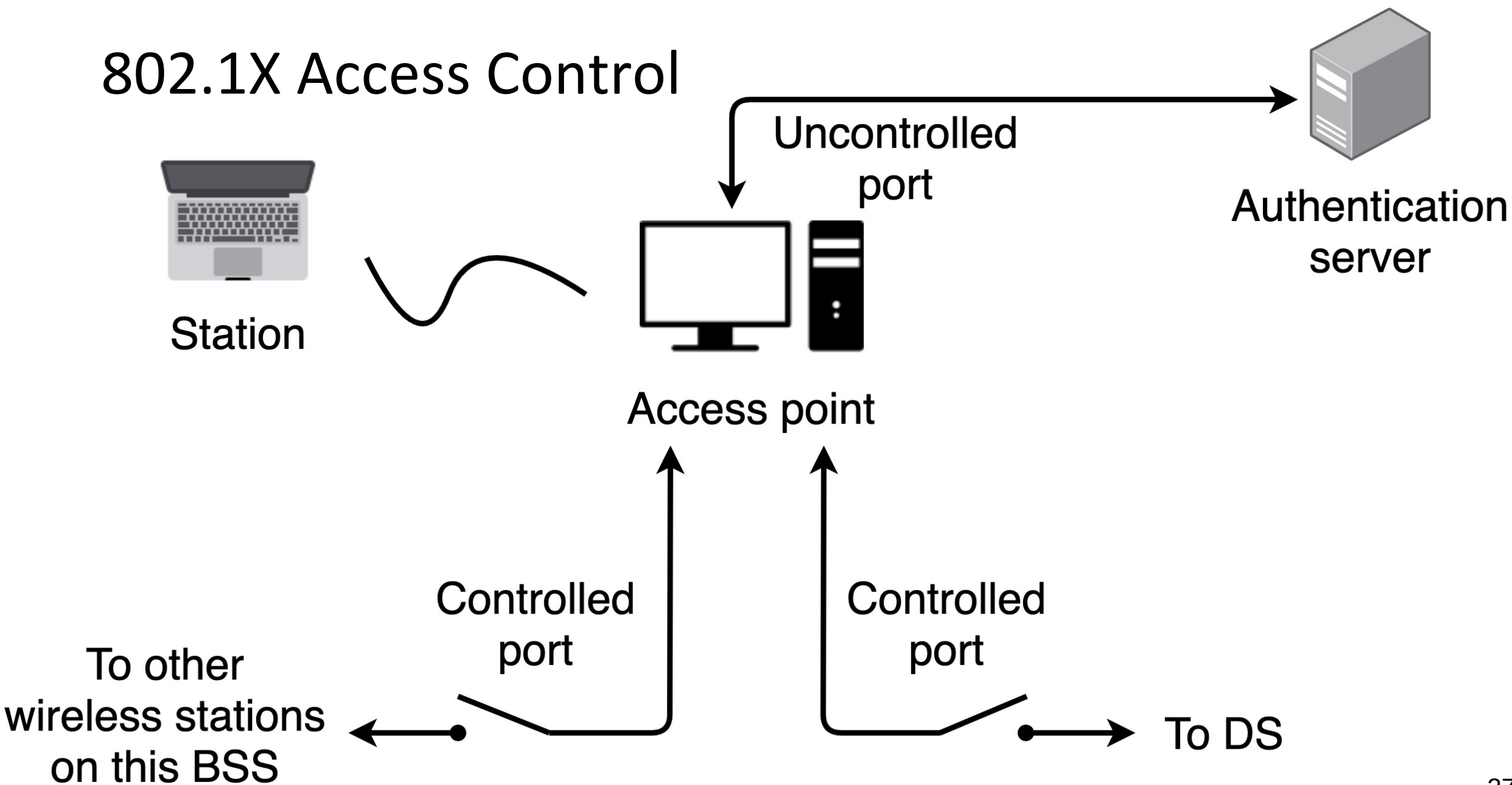
- WEP, TKIP, CCMP, vendor-specific

AKM: Authentication and Key Management

- IEEE 802.1x, pre-shared key, vendor-specific



802.1X Access Control



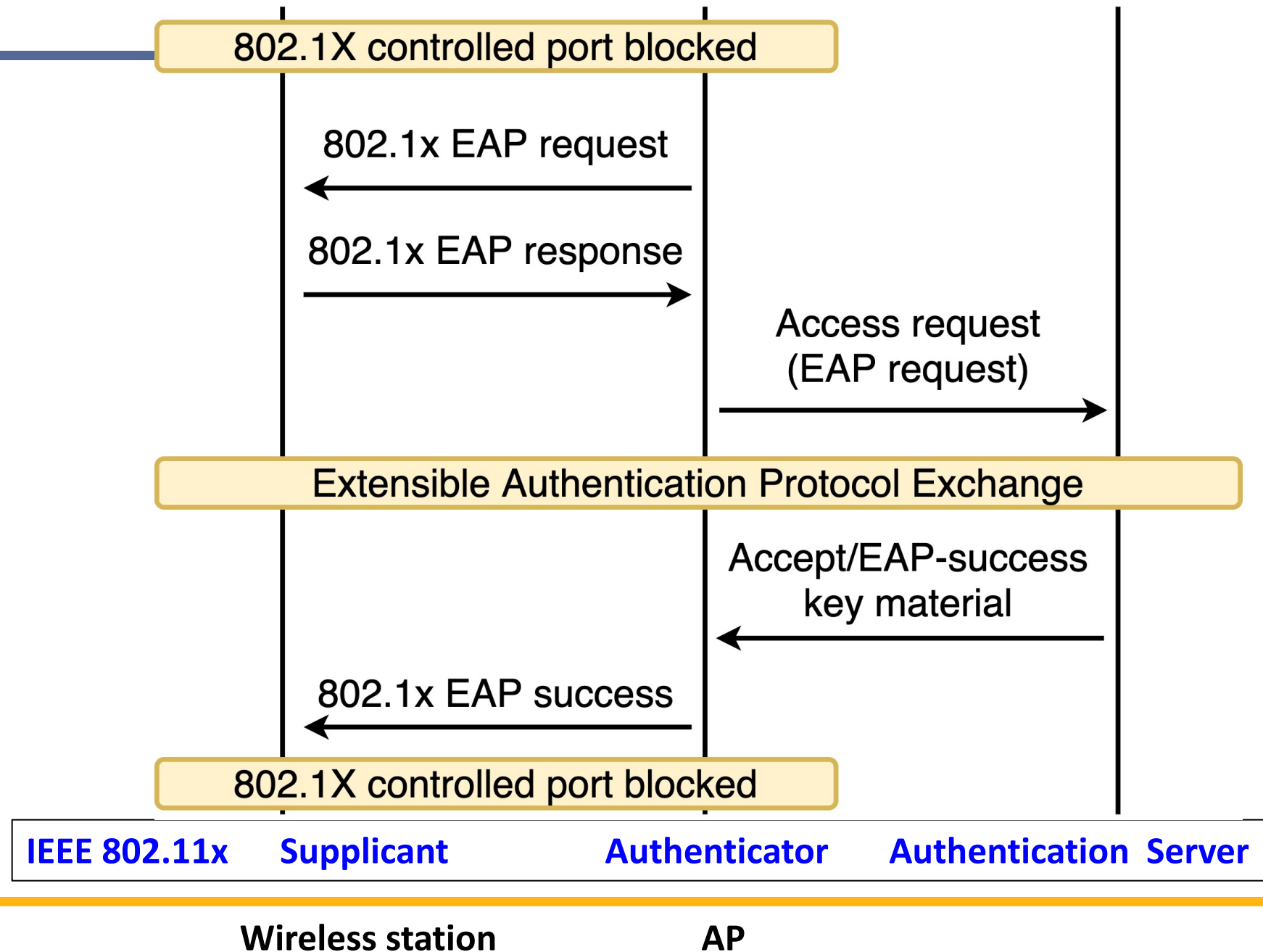
Authentication Phase

IEEE 802.11X AC

- 802.1X Control channel is unblocked
- 802.11 data channel is blocked

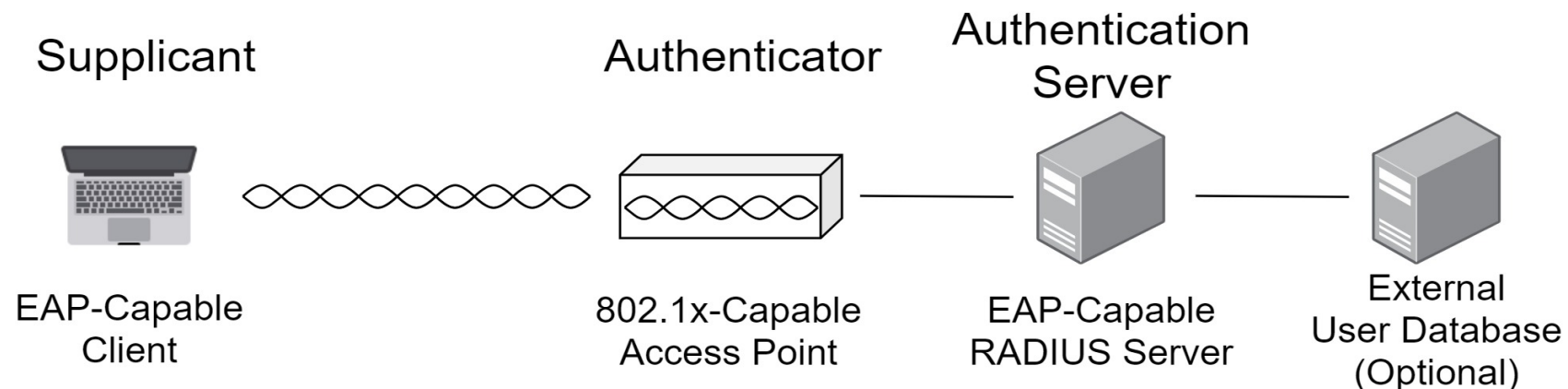
Three phases

- Connect to AS
- EAP exchange
- Secure key delivery



EAP Authentication Protocol

- An Authentication framework, but not a specific mechanism
 - ❑ Providing some common functions
 - ❑ Negotiating authentication methods: EAP methods (more than 40)
- Important notes
 - ❑ EAP authentication is initiated by the server (authenticator)
 - ❑ Authentication is mutual between the client and authentication server



Popular EAP Methods

- Cisco LEAP (Lightweight EAP)

- ❑ A proprietary method developed by Cisco
- ❑ User credentials are not strongly protected: complex passwords are required

- EAP-FAST (EAP-Flexible Authentication via Secure Tunneling)

- ❑ A replacement for LEAP, but non-proprietary
- ❑ No need of strong password or any certificate
- ❑ Using a PAC (Protected Access Credential) to establish a TLS tunnel

- EAP-TLS (EAP-Transport Layer Security)

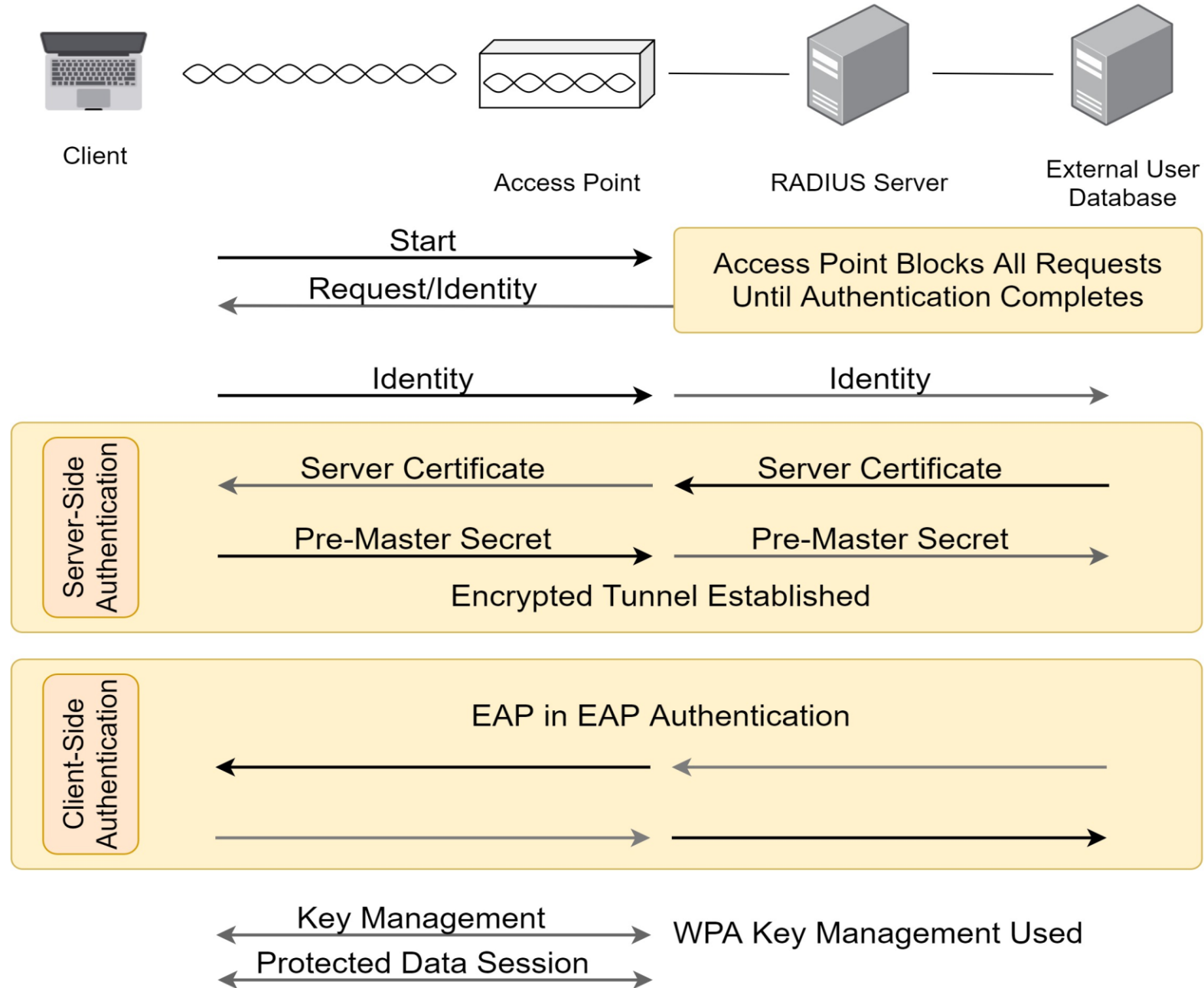
- ❑ (RFC 5216) original, standard wireless LAN EAP authentication protocol
- ❑ Using PKI: both client and AS need a certificate (X.509 certificates)
- ❑ One of the most secure EAP standards available
- ❑ Universally supported by all manufacturers of wireless LAN hardware/software

Popular EAP Methods (Cont.)

- PEAP (Protected EAP)

- ❑ Encapsulating EAP within a potentially encrypted and authenticated TLS tunnel
- ❑ Only the server authentication is performed using PKI certificate
- ❑ Client is authenticated using either EAP-GTC or EAP-MSCHAPv2 within the tunnel
 - EAP-GTC (Generic Token Card)
 - EAP-MSCHAPv2 (Microsoft's Challenge Handshake Authentication Protocol)

PEAP



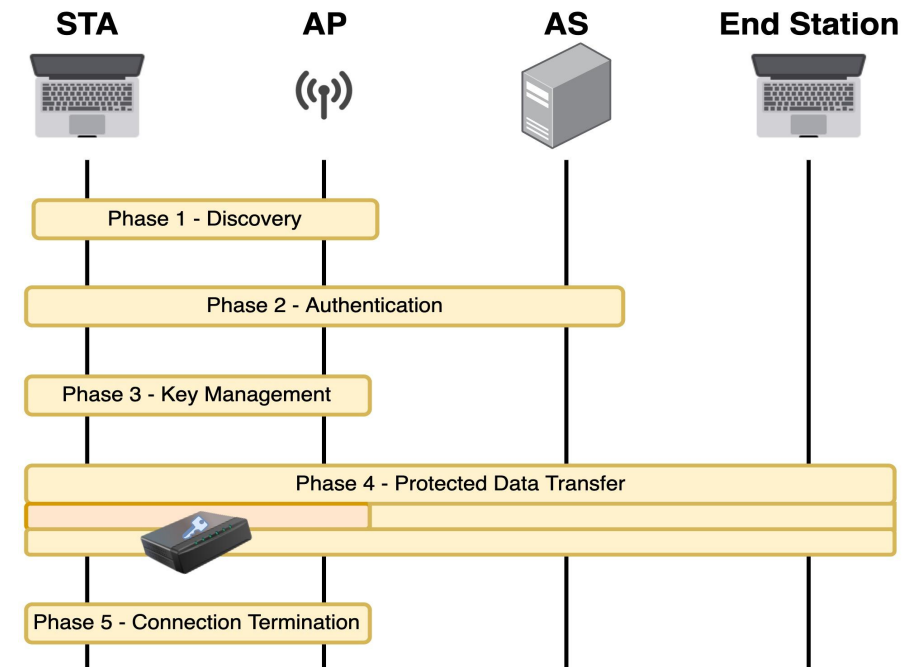
Key Management Phase

- Pairwise keys: for communication between an STA and an AP

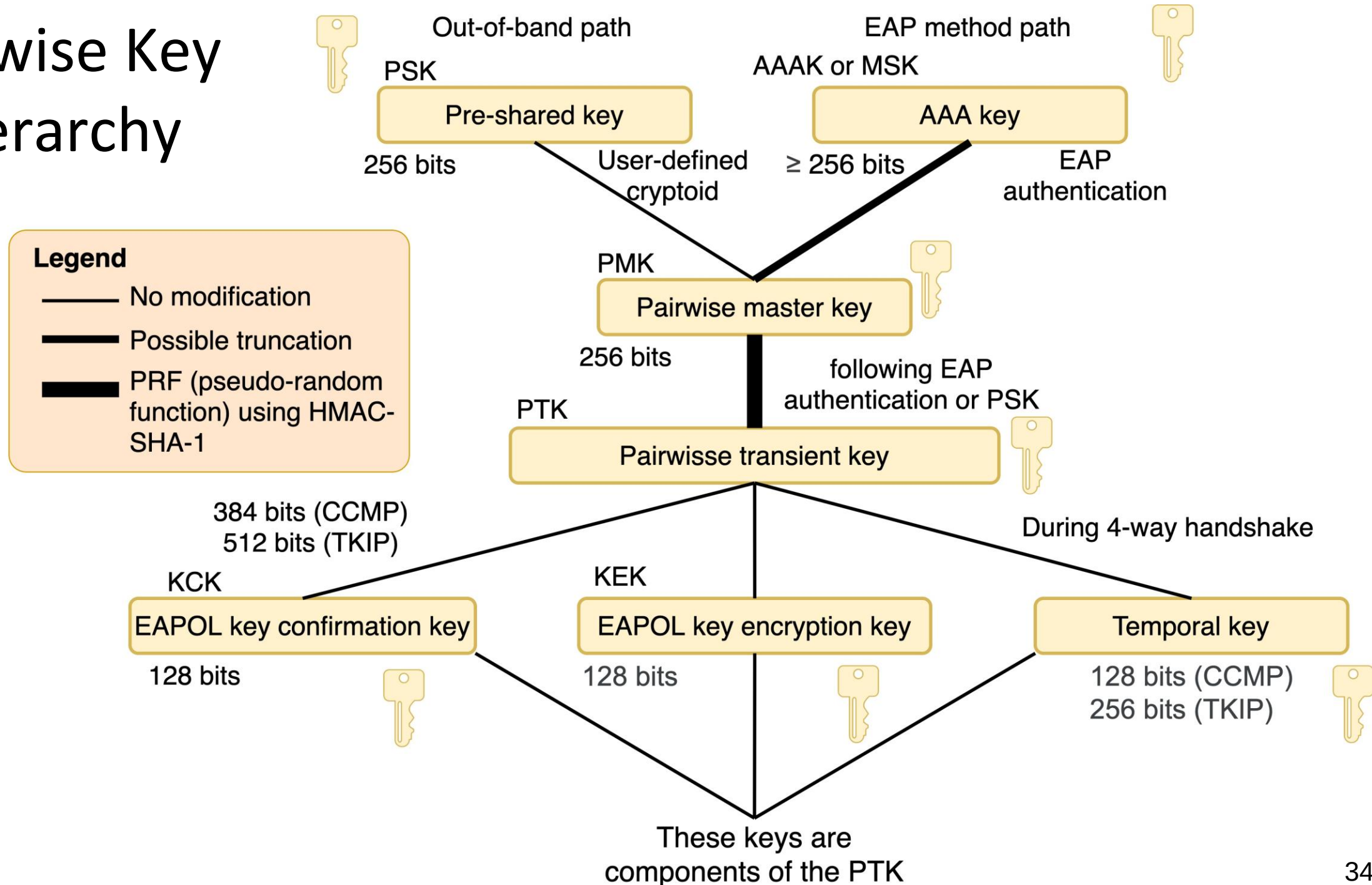
- ❑ Pre-shared key (PSK)
- ❑ Master session key (MSK)
- ❑ Pairwise master key (PMK)
 - PSK or derived from MSK
- ❑ Pairwise transient key (PTK)

- Group keys: for multicast communication

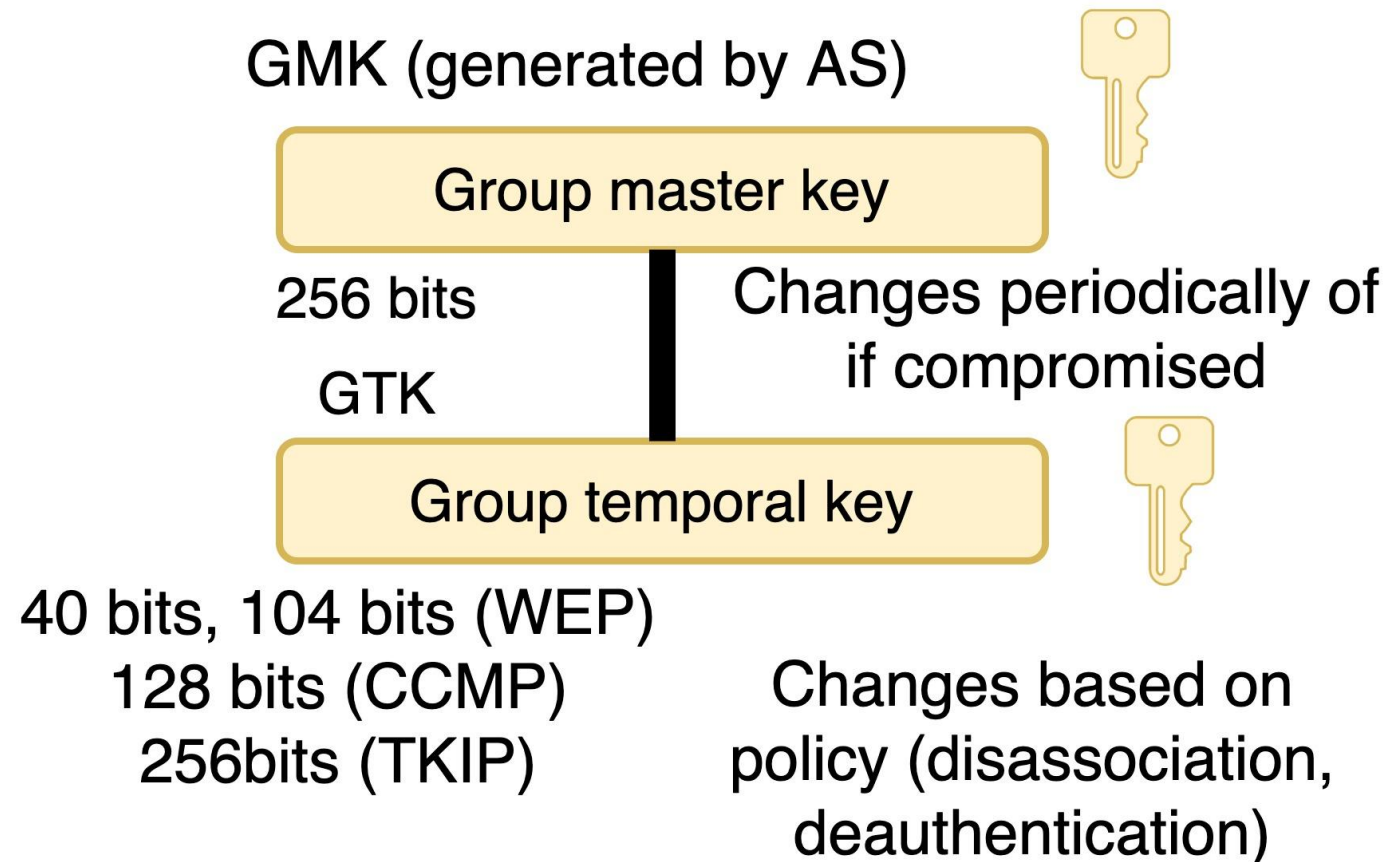
- ❑ Group master key (GMK)
- ❑ Group temporal key (GTK)



Pairwise Key Hierarchy



Group Key Hierarchy





IEEE 802.11i Phases of Operation: 4-way Handshake

AP's 802.1X controlled port blocked

Message 1
EAPOL-key (Anonce, Unicast)

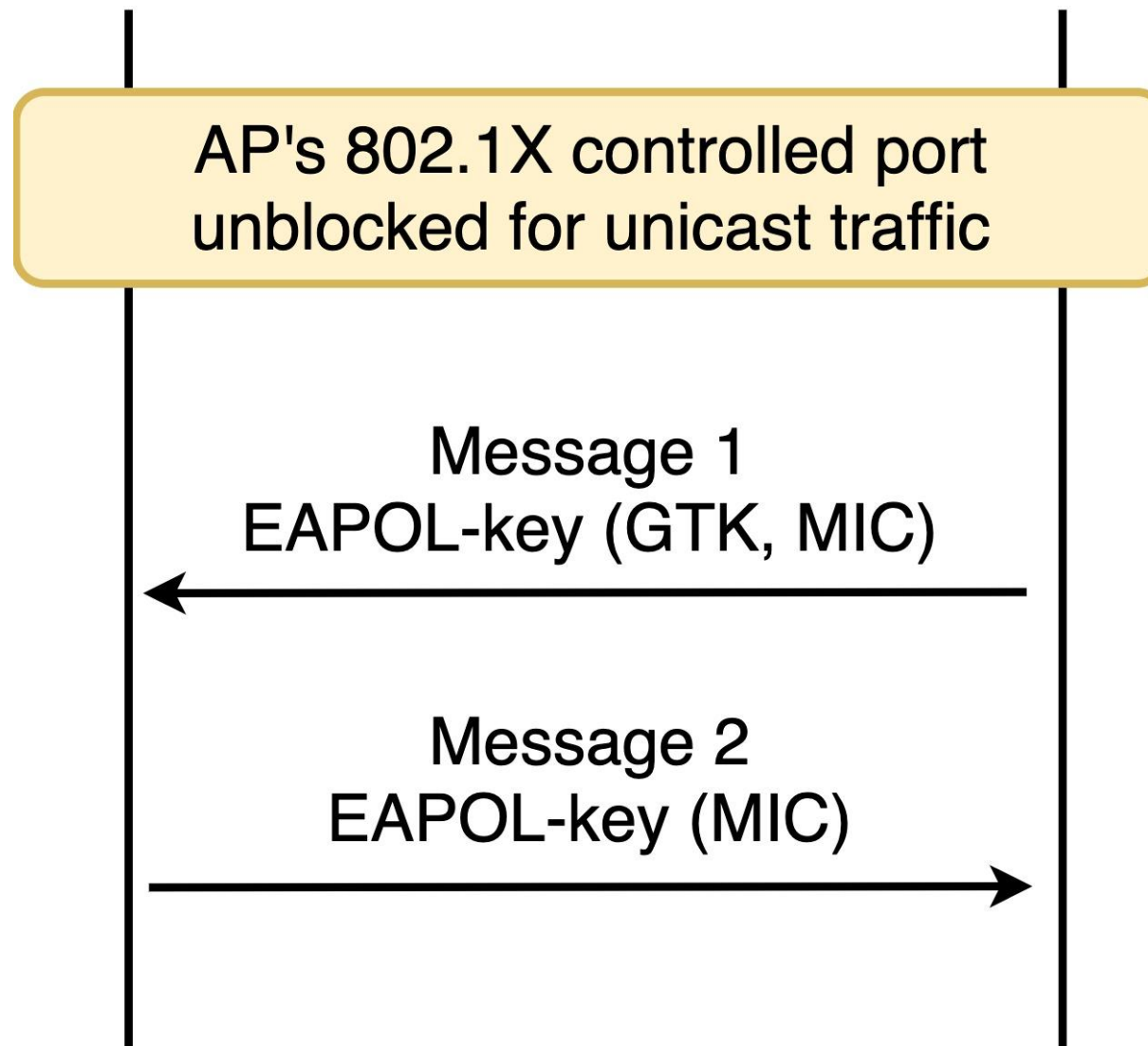
Message 2
EAPOL-key (Snonce,
Unicast, MIC)

Message 3
EAPOL-key (Install PTK,
Unicast, MIC)

Message 4
EAPOL-key (Unicast, MIC)

AP's 802.1X controlled port
unblocked for unicast traffic

IEEE 802.11i Phases of Operation: Group Key Handshake



Protected Data Transfer Phase

● Temporal Key Integrity Protocol (TKIP)

- ❑ Only software changes are required to old WEP
- ❑ Message integrity
 - Message Integrity Code (MIC): by an algorithm, called Michael
 - 64-bit: source/destination MAC addresses + data field + key material
- ❑ Data confidentiality
 - Encrypting MPDU + MIC using RC4
- ❑ 256-bit TK
 - Two 64-bit keys for MIC: one key for each direction
 - 128 bits: generate the RC4 key for encryption
- ❑ TKIP sequence counter (TSC): monotonically increasing
 - Included with each MPDU and protected by MIC → against replay attack
 - Combined with session TK → dynamic encryption key

Protected Data Transfer Phase

- Counter Mode-CBC MAC Protocol (CCMP)
 - ❑ Hardware support is needed
 - ❑ Message integrity
 - Cipher block chaining message authentication code (CBC-MAC)
 - ❑ Data confidentiality
 - CTR block cipher mode of operation with AES
 - ❑ Same 128-bit AES key for both
 - ❑ A 48-bit packet number: a nonce to prevent replay attacks

IEEE 802.11i Pseudorandom Function (PRF)

- A pseudorandom bit stream: HMAC-SHA-1
 - A message and a key (at least 160 bits) → 160-bit hash value
 - SHA-1 property: change of a single bit → a new hash value with no apparent connection

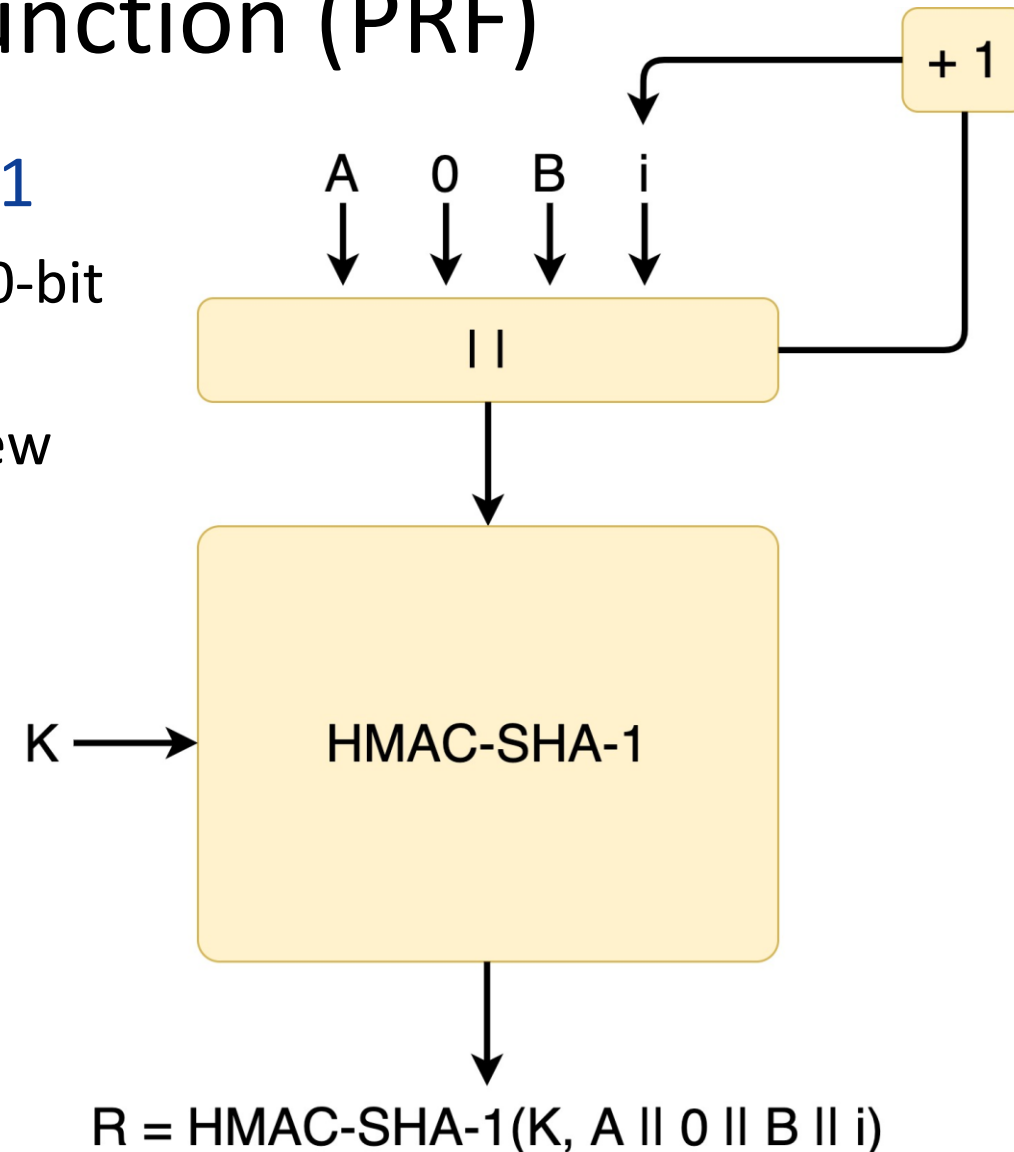
PTK:

$K = \text{PMK}$

$A = \text{"Pairwise key expansion"}$

$B = \text{Concatenation of two MAC address and two nonces}$

$\text{Len} = 384 \text{ bits}$



WPA3

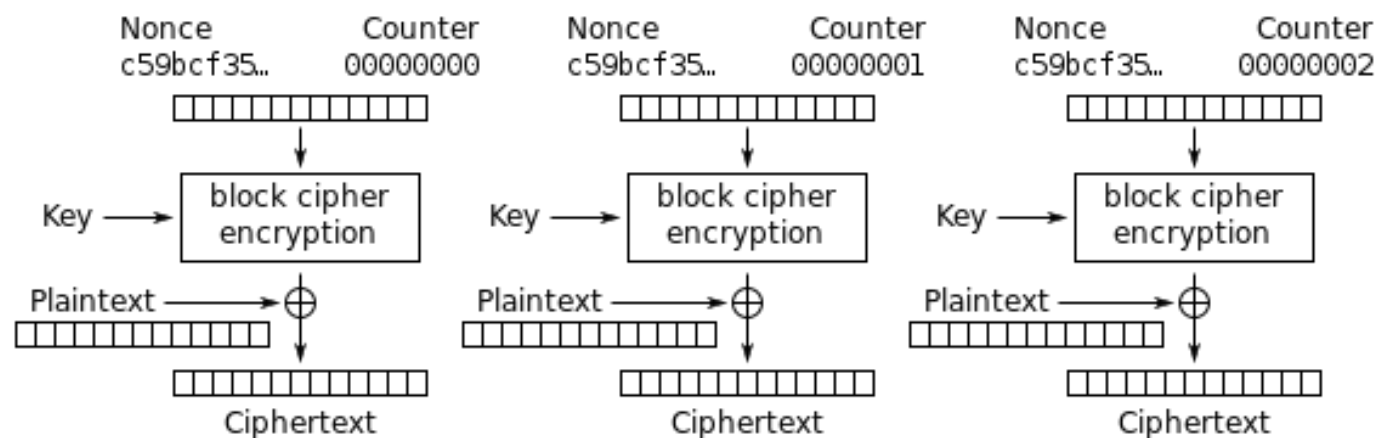
- In Jan. 2018, the Wi-Fi Alliance announced WPA3
 - ❑ A replacement to WPA2
 - ❑ PSK (Pre-Shared Key) WPA and WPA2 remain vulnerable to KRACK (Key Reinstallation Attack)
 - ❑ WPA3 replacing it with SAE (Simultaneous Authentication of Equals)
- KRACK, discovered in 2016
 - ❑ A replay attack on the Wi-Fi Protected Access protocol
 - ❑ By repeatedly resetting the nonce transmitted in the 3rd step of WPA2 handshake
 - ❑ An attacker can gradually match encrypted packets seen before and learn the full keychain used to encrypt the traffic

WPA2-PSK

- A Wi-Fi password shared between AP and clients
- PMK is generated based on PBKDF2 (Password-Based Key Derivation Function 2)
 - $\text{PMK} = \text{PBKDF2}(\text{passphrase}, \text{SSID}, 4096 \text{ iterations}, 256 \text{ bits})$
- PMK is then used in the 4-way handshake to drive the PTK
 - If the password is weak, an attacker can capture the 4-way handshake
 - Try password guesses offline, by re-generating the key and seeing if it matches the captured handshake → Offline dictionary attack

KRACK

- Not only enables us to decrypt the traffic, but depending on the initial setup it can lead to forging and even injecting data frames sent to the client

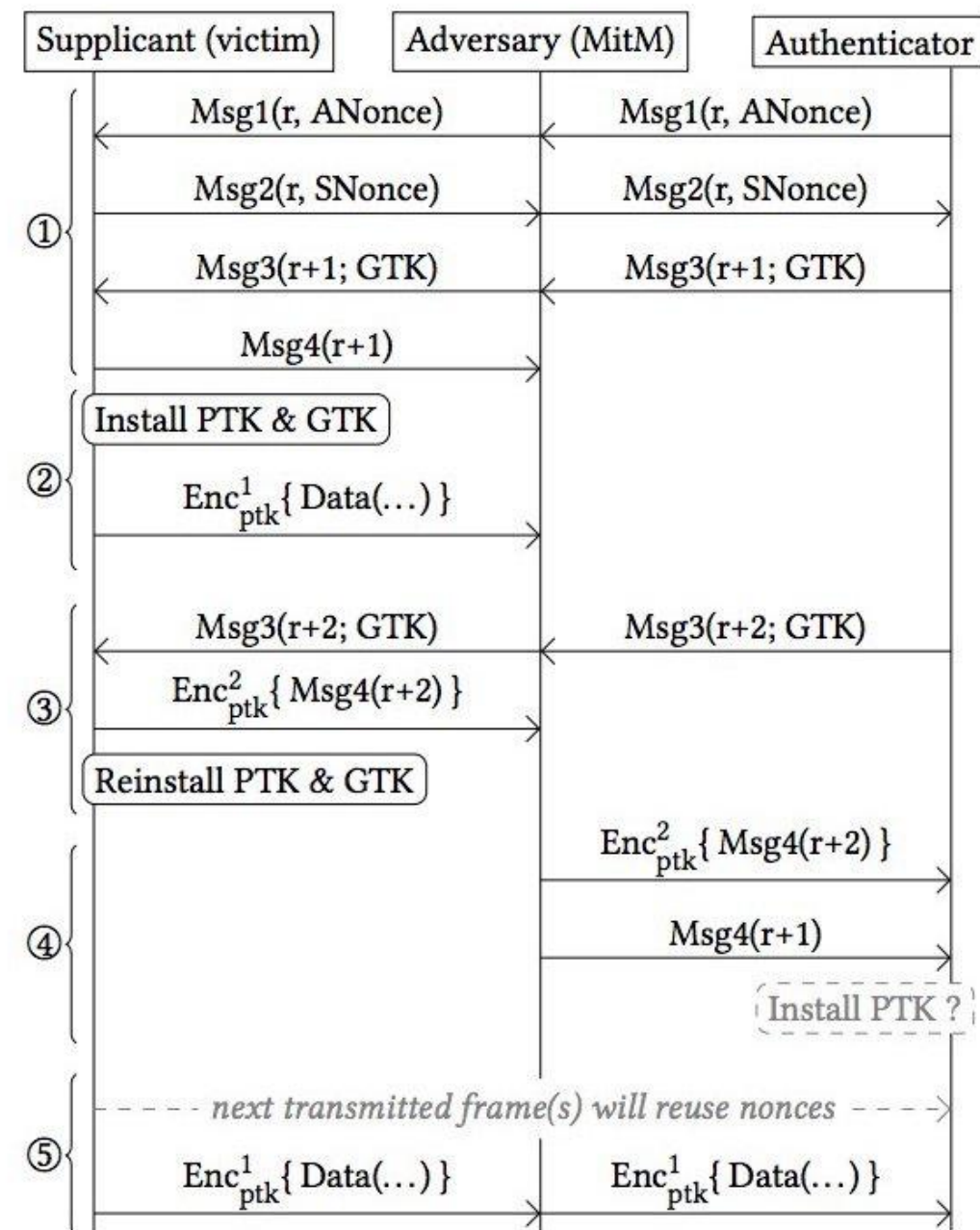


Counter (CTR) mode encryption

The keystream must not be reused!!

Consider: $(A \oplus K) \oplus (B \oplus K) = A \oplus B$

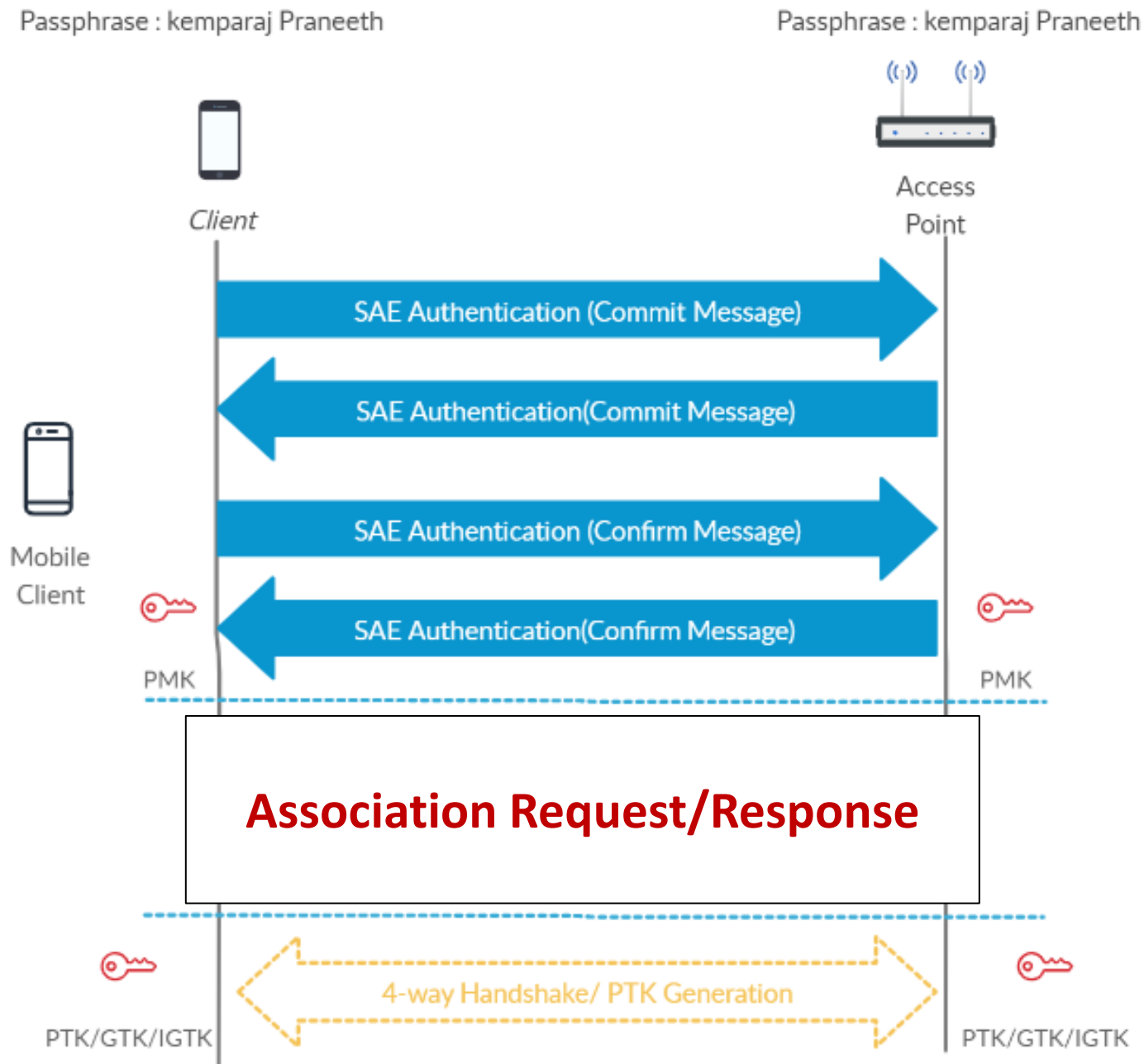
KRACK website: <https://www.krackattacks.com/>



SAE

- A secure password-based key exchange protocol
 - A variant of the Dragonfly key exchange
 - Letting two devices prove to each other that they know the same password
 - Without ever sending the password or anything derived from it
- How it works?
 - Instead of using the shared password directly
 - Converts the password into a mathematical point on a curve (elliptic curve)
 - Uses Diffie-Hellman-like operations with randomness to create a shared secret
 - They exchange commitment message (not the password or key itself)
 - Each side proves knowledge of the password by computing the same session key

SAE (cont.)



Reference:

<https://praneethwifi.in/2021/03/10/wpa3-authentication-part-2/>

SAE (cont.)

● Commit Message from Client to AP

- ▷ Frame 1114: 157 bytes on wire (1256 bits), 157 bytes captured (1256 bits) on interface en0, id 0
- ▷ Radiotap Header v0, Length 25
- ▷ 802.11 radio information
- ▷ IEEE 802.11 Authentication, Flags:C
- ▲ IEEE 802.11 Wireless Management

- ▲ Fixed parameters (104 bytes)

Authentication Algorithm: Simultaneous Authentication of Equals (SAE) (3)

Authentication SEQ: 0x0001

Status code: Successful (0x0000)

SAE Message Type: Commit (1)

Group Id: 256-bit random ECP group (19)

Scalar: 9181febd30ccb5870fa5784c9fc4de5102bdfd9ec35bd048...

Finite Field Element: b795ecb918cfb0b40ba21dbda615116a4005cca6ea1e932a...

Public data goes in Commit message , And FFE contains X and Y point each 32 Byte Size.

Public data does not mean that it is cleartext, it is hashed public data

```

0000 00 00 19 00 6f 08 00 00 7b 5f d5 03 00 00 00 00  ....o... {_.....
0010 10 02 6c 09 80 04 d4 9e 00 b0 00 00 00 e8 de 27  ..l.....'
0020 a6 67 a8 e8 de 27 a9 94 fb e8 de 27 a6 67 a8 20  .g...'..'.g.
0030 25 03 00 01 00 00 00 13 00 91 81 fe bd 30 cc b5  %.....0..
0040 87 0f a5 78 4c 9f c4 de 51 02 bd fd 9e c3 5b d0  ...xL... Q.....[
0050 48 06 bb 70 8c ca eb ae ac b7 95 ec b9 18 cf b0  H..p.....
0060 b4 0b a2 1d bd a6 15 11 6a 40 05 cc a6 ea 1e 93  .....j@.....
0070 2a f7 a2 6b 20 15 81 a8 c1 98 88 dd 00 88 f1 cb  *.k.....
0080 ed 47 e8 05 50 69 88 26 95 6f 32 47 fd 70 24 07  \G..Pi.& .o2G.p$.
0090 12 dd fc b8 96 b5 78 66 ca 45 4c 13 74  ....xf.EL.t

```

Green Color Data is Point Commit X (32 Byte), Blue color Data is Commit Y (32 Byte)

Reference:

<https://praneethwifi.in/2021/03/10/wpa-3-authentication-part-2/>

SAE (cont.)

● Confirm Message from Client to AP

- Frame 1120: 93 bytes on wire (744 bits), 93 bytes captured (744 bits) on interface en0, id 0
- Radiotap Header v0, Length 25
- 802.11 radio information
- IEEE 802.11 Authentication, Flags:C
- IEEE 802.11 Wireless Management
 - Fixed parameters (40 bytes)
 - Authentication Algorithm: Simultaneous Authentication of Equals (SAE) (3)
 - Authentication SEQ: 0x0002
 - Status code: Successful (0x0000)
 - SAE Message Type: Confirm (2)
 - Send-Confirm: 0
 - Confirm: a4e72c81d4c2c69753aa00c965f84cd61c9e8a12d8a55fee...

Reference:

<https://praneethwifi.in/2021/03/10/wpa-3-authentication-part-2/>

Security Improvements

● WPA2

- ❑ Uses Pre-Shared Key (PSK) or Enterprise mode
- ❑ Vulnerable to offline dictionary attacks (especially if a weak password is used)
- ❑ Data encryption using AES-CCMP

● WPA3

- ❑ Replaces PSK with SAE in personal mode
- ❑ Much stronger against brute-force/dictionary attacks
- ❑ Still uses AES, but Enterprise mode optionally supports 192-bit encryption

	WPA2	WPA3
Authentication	PSK/802.1X	SAE/802.1X
Offline Dictionary Protection	Weak	Strong (SAE)
Forward Secrecy	No	Yes
Encryption	AES-CCMP	AES-GCMP (optional)
KRACK Resistance	No (Patched)	Yes (Built-in)
Wi-Fi Easy Connect	No	Yes
Device Compatibility	Broad	New devices only

Questions?